Bridging Security and Usability: Evidence-Based Design of Risk-Based Authentication Email Notifications

Dhyanshekar M Bettahalsoor (S4144874), Anthony Mackenzi Fernando (S4129857),
Bhaargava Ramesh (S4115644), Daniel George (S4145079),
Rahul Adithya Badenahalli Muralidhar (S4137945)

Group 6, Practical 2, INTE2675 Human Centered Security
School of Computing Technologies, RMIT University, Melbourne, Australia

***Abstract* – Risk-based authentication (RBA) adapts sign-in requirements to contextual risk, but its protective value depends on whether users understand and act on the emails it sends. We designed eight RBA email notifications for the central sign-in platform of a fictional organisation, using a provided risk model and Protection Motivation Theory (PMT), and evaluated them in a qualitative role-play study in which six participants thought aloud while reading four emails each, answered a semi-structured interview and rated each email. Reflexive thematic analysis produced eight themes. Participants judged every email first by whether an attacker got in, and wording that implied access undermined comprehension. Severity was judged from password knowledge and role rather than tier colour. Trust rested on checkable cues and was lost through urgent wording, which all three viewers of the High-risk reset email linked to phishing. Confidence depended on plain terms and a stated reason for each step, and at high stakes most participants would call the Service Desk or type the portal address rather than click. We propose five refinements to the templates.**

I. Introduction

Passwords alone no longer protect organisational accounts adequately, and multi-factor authentication (MFA) adds effort to every sign-in. Risk-based authentication (RBA) targets that effort: it scores each sign-in against contextual signals such as device, network, location, time and failed-attempt velocity, then steps up, restricts or locks the account in proportion to the score. Users have rated RBA as more usable than always-on two-factor authentication while still perceiving it as protective [1].

RBA's effectiveness does not depend only on accurate scoring. When the system acts it usually emails the user, who must understand what happened, decide whether the activity was theirs and complete any recovery step. Users want enough information to understand who may be accessing their account and why they were notified, and unclear notifications can be mistaken for phishing or set aside [2]. Frequent, similar warnings also invite habituation [3], [4]. An email that is misunderstood, distrusted or put off weakens the protection the risk model was designed to give.

This project designed RBA emails for the central single sign-on platform of Meridian, a fictional organisation of several thousand employees. Three events (correct password, incorrect password and password reset request) are considered for three roles (regular staff, management staff and administrator). A provided risk model [5] sets the risk score, tier and system response for each event, and each email must describe that response accurately.

Aim. To design, evaluate and refine RBA email notifications that help internal users understand authentication-related risks and take appropriate security action.

Objectives.

1) Design eight RBA email templates covering the events and risk tiers for which the risk model sends an email.
2) Develop eight realistic scenarios, one per template, grounded in the risk model.
3) Evaluate the notifications in a qualitative study with six participants and identify usability and security problems.
4) Develop evidence-based recommendations for refining the templates.

II. Methodology

A. RBA Notification Design

1) Behavioural theory: We used Protection Motivation Theory (PMT) [6], [7], [8]. An RBA email is a fear appeal: it reports a possible threat and asks for protective action. PMT holds that such a message works through threat appraisal (perceived severity and susceptibility) and coping appraisal (response efficacy and self-efficacy, offset by response cost). Protective action is most likely when both are strong; a strong threat with weak coping produces avoidance or delay [9], [10], of which ignoring security emails is one form. We therefore adopted one design rule at the first team meeting: wherever a template raises threat appraisal, it must raise coping appraisal by at least as much. The Theory of Planned Behaviour, the Technology Acceptance Model and Technology Threat Avoidance Theory were set aside: a notification is read suddenly and alone, is not a technology users adopt, and needs PMT's response-cost construct to match effort to tier.

2) Template structure: All eight emails share a ten-region skeleton in a fixed order: envelope (verified sender, subject, recipient, timestamp), brand header, colour-coded status label, headline, personal summary, "What we've done", action zone, "What happened" panel, legitimacy cues and a reference footer. The envelope, header, cues and footer are identical in every email; the label, headline, "What we've done" and action zone change by tier; the summary and panel are filled per scenario.

Table I maps each PMT construct to these regions. Fuller technical detail in the panel was rejected at the Week 6 meeting to limit overload.

TABLE I
PMT CONSTRUCTS AND THE TEMPLATE FEATURES THAT CARRY THEM

PMT construct	Template region and feature
Perceived severity	Tier colour (blue, orange, red), status label ("Security notice", "Action needed", "Account locked") and headline
Perceived susceptibility	Summary with unusual signals highlighted; "What happened" panel: event, time, approximate place, device, network, outcome
Response efficacy	"What we've done" states the automated response; every action states what it achieves
Self-efficacy	One primary action, plain wording, numbered steps for Critical events, Service Desk fallback
Response cost	Effort scaled to tier: confirm or deny (Medium), one guided flow (High), three steps of about 5 minutes (Critical)

3) Alignment with the risk model: Each email states only what the risk model says the system has done (Table II). Low-risk events (0 to 50) send no email, and an incorrect password at Medium risk sends none to avoid alert fatigue, so the set has eight templates rather than nine. Medium emails accompany the number-matching step-up and, because a failed step-up escalates to Critical, warn that a failed check locks the account. High emails list the blocked sensitive actions and note that no further email will be sent during verification; Critical emails note that the security team has been alerted.

TABLE II
WHAT CHANGES BETWEEN TIERS

Tier (score), label	System action	Email role	User effort, primary action
Medium (51–115) Blue, "Security notice"	Access or reset continues after number-match step-up	Explains the check alongside the prompt	Complete the check or deny it; no button
High (116–150) Orange, "Action needed"	Action blocked; account restricted; sensitive actions blocked	Explains the restriction; one secure pathway; no further email	One guided step-up flow; "Secure my account"
Critical (>150) Red, "Account locked"	Account locked; action permanently blocked; security team alerted	Explains the lock; sets out manual recovery	Three steps (about 5 min), Service Desk fallback; "Start account recovery"

4) Usability and legitimacy: Usability was addressed through plain language, one primary action with a stated reason, numbered steps with a time estimate for Critical recovery, and one layout at every tier. A generic "check account activity" link was rejected at the Week 7 review because choice invites delay. Legitimacy was addressed through six cues against phishing confusion: one verified sender and domain (security@id.meridian.com, all links on id.meridian.com); specific details an attacker is unlikely to hold; the statement that Meridian never asks for passwords or codes by email; advice to type id.meridian.com rather than click; buttons that show their destination; and a reference the Service Desk can confirm.

5) Worked example: Fig. 1 shows the Scenario 4 email (incorrect password, High risk, regular staff; (25 + 60 + 15 + 25) × 1.0 = 125). A wrong password never grants access, but this score restricts the account and requires a secure pathway. The design translates this as follows.

- *Severity:* orange "ACTION NEEDED" label and the headline "6 failed sign-ins from an unknown device".
- *Susceptibility:* the summary highlights the signals ("6 failed sign-in attempts in five minutes from an unrecognised device on a high-risk network"), and the panel repeats them.
- *System response:* "No one got in – a wrong password never grants access", "All attempts failed – no access", and the restriction listed exactly as the model specifies.
- *Response efficacy:* "This verifies it's you, lifts the restriction and lets you set a stronger password so further guesses fail."
- *Self-efficacy and cost:* one "Secure my account" button labelled "Opens id.meridian.com/secure", and "You won't receive another email during this process."
- *Legitimacy:* verified sender, how-to-check box and reference RBA-260922-1436.

All three participants who saw this email rated it 4 or 5 for understanding and 5 for confidence.

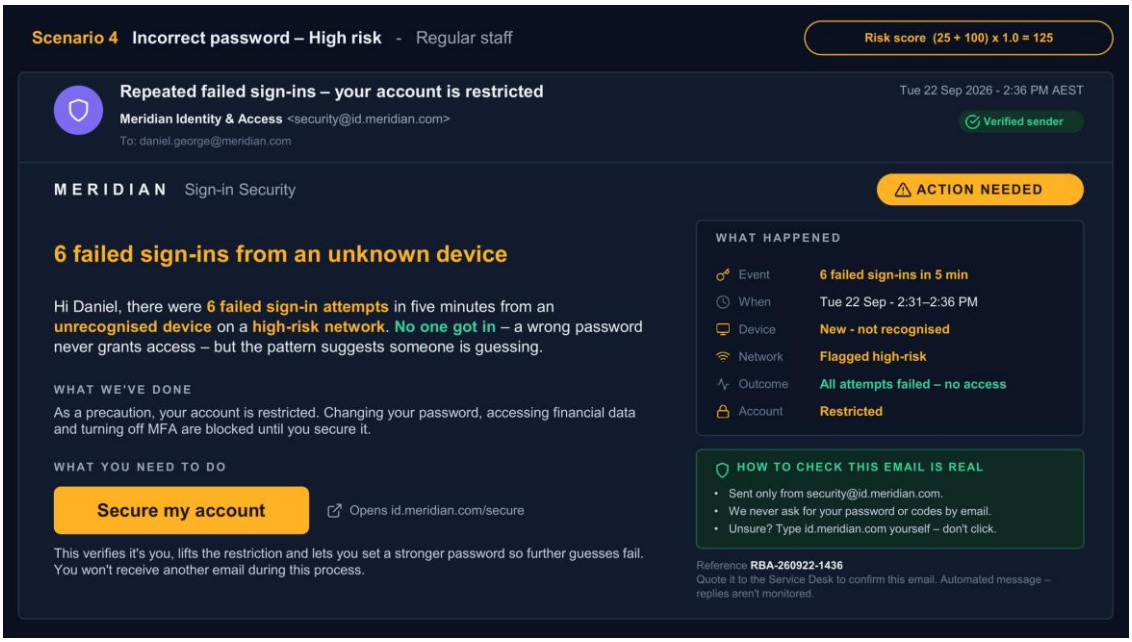


Fig. 1. Scenario 4 notification, Version 1.0 (incorrect password, High risk, regular staff), with its risk score in the header bar; Section II-A5 maps each region to the PMT construct it carries.

B. Scenario Development

We wrote one scenario for each of the eight event and tier combinations that send an email (Table III), choosing a role and contextual signals whose score falls inside the target tier and checking every calculation, including the two that round up (142.5 to 143, 202.5 to 203). Roles were assigned so the role multiplier is experienced rather than described. Scenarios are written in the second person, set a short situation (for example, signing in from a new laptop on hotel Wi-Fi), state the role and say what the system has already done, so comprehension of the response can be tested separately from the event. S1 and S6 describe activity the participant initiated; the others do not. Participants did not see the calculation. Each participant saw four scenarios to limit load; every scenario had three viewers, every participant saw all three events and at least two roles, and order varied.

TABLE III
SCENARIOS, RISK CALCULATIONS AND VIEWERS

#	Event	Tier	Role	Contextual signals	Risk score	Viewers
S1	Correct password	Medium	Regular staff	New device (+15), unusual location (+20)	(20 + 35) × 1.0 = 55	P1, P4, P6
S2	Correct password	High	Management	New device (+15), high-risk IP (+25), impossible travel (+35)	(20 + 75) × 1.5 = 143	P1, P3, P5
S3	Correct password	Critical	Administrator	New device (+15), high-risk IP (+25), unusual time (+10), unusual location (+20)	(20 + 70) × 2.0 = 180	P2, P4, P5
S4	Incorrect password	High	Regular staff	5+ failures in 15 min (+60), new device (+15), high-risk IP (+25)	(25 + 100) × 1.0 = 125	P2, P3, P5
S5	Incorrect password	Critical	Management	10+ failures in 24 h (+60), new device (+15), impossible travel (+35)	(25 + 110) × 1.5 = 203	P1, P4, P6
S6	Reset request	Medium	Regular staff	New device (+15), unusual time (+10)	(30 + 25) × 1.0 = 55	P2, P3, P5
S7	Reset request	High	Management	New device (+15), high-risk IP (+25), unusual location (+20)	(30 + 60) × 1.5 = 135	P2, P4, P6
S8	Reset request	Critical	Administrator	New device (+15), high-risk IP (+25), impossible travel (+35)	(30 + 75) × 2.0 = 210	P1, P3, P6

C. User Study Design

1) Design: A qualitative study combining scenario-based role-play, concurrent think-aloud [11] and a semi-structured interview in one session per participant. Role-play allowed responses to events that cannot ethically be staged on real accounts, and role cards conveyed the higher stakes of manager and administrator accounts. Think-aloud captured first impressions; the interview probed comprehension and each PMT construct; three ratings per email gave a cross-check, each followed by the participant's reason.

2) Recruitment and ethics: Participants were recruited from Week 9 through team members' personal and professional contacts. They had to be over 18, regular users of password-protected online accounts and not members of the team. The

planned six to eight was fixed at six at the Week 8 meeting, still giving three viewings per scenario. The Participant Information and Consent Form (PICF) explained the purpose, audio-only recording, de-identification, storage in a password-protected RMIT account and the right to withdraw; the protocol required facilitators to confirm the signed form and obtain verbal consent on the recording.

3) Study materials: The materials were the PICF (Version 1, 21 September 2026); the eight emails (Version 1.0), issued after review against the risk model and a PMT checklist at the Week 7 meeting; the eight scenarios with three role cards stating what each role can reach (managers add team records, budgets and approvals; administrators add account creation, password resets and MFA rules); and the data collection instrument (Version 1, 21 September 2026). The instrument holds an opening script, three background questions, an eleven-question block per email (event and response comprehension, recognition, seriousness, intended action, each PMT construct, legitimacy, one suggested change), three rating items, a neutral probe bank and closing questions. The team reviewed the documents at the Week 8 and 9 meetings.

4) Participant characteristics: Six adults took part (Table IV), from a workplace booking system, education, IT support, office administration, a hospital ward with shared computers and a marketing team. Four used an authenticator app and knew number matching; two relied mainly on SMS codes. Researcher-judged technical familiarity was low for two, medium for three and high for one. Three described a memorable phishing experience, one having failed a workplace phishing test, and four usually ignore login alerts because they caused them. Age and gender were not collected.

TABLE IV
PARTICIPANTS AND SESSIONS

P	Facilitator	Date (Oct)	Min	Scenario order	Work context	MFA experience (knew number matching)	Tech. familiarity	Prior phishing
P1	Dhyanshekar	19	35	S1, S5, S8, S2	Workplace with booking system	Authenticator app, SMS (yes)	Medium	No
P2	Rahul	22	29	S3, S4, S7, S6	Education	SMS, Google prompts (no)	Low	Yes
P3	Daniel	23	33	S2, S4, S8, S6	IT support; student	App, hardware key, passkeys, SMS (yes)	High	No
P4	Bhaargava	19	34	S5, S1, S7, S3	Office administration	SMS daily; finds app confusing (no)	Low	Yes
P5	Anthony	19	23	S6, S3, S4, S2	Hospital ward, shift work	Authenticator with number matching (yes)	Medium	No
P6	Dhyanshekar	12	24	S7, S1, S5, S8	Marketing, social media	Authenticator app, SMS, Google prompts (yes)	Medium	Yes

5) Data collection procedure: Sessions ran online over Microsoft Teams between 12 and 23 October 2026 and lasted 23 to 35 minutes. Dhyanshekar facilitated P1 and P6; Rahul, Daniel, Bhaargava and Anthony facilitated P2 to P5, one each, all using the same instrument. Each session ran as follows.

1) *Framing and consent:* the facilitator explained that the designs, not the participant, were being tested, confirmed the PICF and obtained verbal consent to recording, repeated on the recording, with a reminder that questions could be skipped and the session stopped.
2) *Setting and background:* a large organisation with one central sign-in and an authenticator app that sometimes asks to approve or deny a sign-in; then the three background questions.
3) *Scenario loop (four times):* the facilitator read the role card and scenario, shared the email on screen and stayed silent while the participant thought aloud; asked the eleven questions; and collected three ratings from 1 (strongly disagree) to 5 (strongly agree): “This email was easy to understand”, “I believe this email is genuinely from my organisation” and “I would feel confident doing what this email asks”, each followed by “What made you give that number?”
4) *Closing:* comparison questions (clearest, most confusing, most serious, what was missing, whether they would keep reading such emails) and thanks.

Facilitators were instructed not to confirm answers, explain the emails or suggest actions. The data comprise audio recordings (no video) with automatic Teams transcripts, think-aloud and interview responses for 24 participant and scenario pairs plus background and closing answers; 72 ratings (6 participants × 4 emails × 3 items); and the attributes in Table IV. Recordings and the participant-to-code register stay in RMIT storage and are not submitted.

D. Data Analysis

1) Approach: We used reflexive thematic analysis [12], [13], [14] with a hybrid frame agreed at the Week 10 meeting: the five PMT constructs and four study questions (event comprehension, system-response comprehension, legitimacy or phishing suspicion, design feedback) as deductive categories, with codes that fitted none added inductively (for example alert fatigue). The unit of analysis was a meaningful segment of participant speech, which could carry several codes. NVivo held each transcript as a case classified by the attributes in Table IV, with each scenario a structural code so codes could be compared across emails.

2) Steps: We followed the six phases of thematic analysis.

1) *Familiarisation:* all six transcripts were read in full and de-identified.
2) *Initial codes:* The first pass, guided by the agreed frame, coded the transcripts and drafted a codebook with a

definition and example quote per code: 378 extracts and 524 code applications across 51 codes, loaded into NVivo for team review.

3) *Searching for themes:* codes were grouped by the construct they informed and their pattern across emails.
4) *Reviewing themes:* each candidate was checked against all six transcripts and a code-by-scenario matrix. Under the Week 11 rule, a theme counts as a finding only if more than one participant supports it; five single-participant codes stay in the audit trail only.
5) *Defining and naming:* themes T1 to T8 were named (Table VI), with PMT constructs held as NVivo sets so deductive and inductive results can be read together.
6) *Reporting:* quotes are verbatim and cited as (participant, scenario); prevalence is given as participants of six, or viewers of three.

3) People, roles and consistency: Under the work plan, Dhyanshekar led the coding frame and analysis with Rahul and Bhaargava; Daniel and Dhyanshekar drafted the findings; and Anthony and Bhaargava linked the themes to the refinement matrix. The first pass was loaded into NVivo again so the team could check, refine or reject each code after review. For consistency, the team agreed at the Week 10 meeting that Dhyanshekar and Rahul would code the same transcript independently, compare their coding with NVivo's Coding Comparison query, discuss each disagreement to consensus and record the decision in the codebook. As reflexive thematic analysis treats coding as interpretive [13], [15], agreement serves as a check on shared understanding of the codebook rather than a reliability threshold.

4) Ratings: Ratings are summarised as medians and ranges. With three per email they support the qualitative findings only, and no statistical tests were applied (Week 10 decision). Nine ratings garbled by transcription (for example "Das food" for "that's four") were inferred from the participant's stated reason and are flagged in the dataset.

III. Findings

Participants could restate each email's event in their own words; where comprehension broke down, it concerned whether an attacker had got in. Problems clustered in specific wording rather than in the template structure. Table V summarises the ratings and Table VI the eight themes, each supported by all six participants.

TABLE V
Ratings per Email, Median (Range)

Email	Easy to understand	Genuine	Confident to act
S1 Correct, Medium	5 (4–5)	5 (4–5)	5 (4–5)
S2 Correct, High	4 (4–4)	4 (4–5)	5 (5–5)
S3 Correct, Critical	4 (3–4)	4 (4–4)	3 (3–4)
S4 Incorrect, High	5 (4–5)	4 (4–4)	5 (5–5)
S5 Incorrect, Critical	4 (3–4)	4 (3–4)	3 (2–4)
S6 Reset, Medium	5 (5–5)	5 (5–5)	5 (5–5)
S7 Reset, High	4 (4–4)	3 (2–3)	3 (3–4)
S8 Reset, Critical	4 (4–5)	4 (3–4)	4 (4–4)
Medium, blue (n = 6)	**5**	**5**	**5**
High, orange (n = 9)	**4**	**4**	**5**
Critical, red (n = 9)	**4**	**4**	**4**

Three ratings per email; 1 = strongly disagree, 5 = strongly agree.

Medians fell from 5 for Medium emails to 4 for most High and Critical emails. The High-risk reset email (S7) had the lowest genuineness median, 3 (range 2 to 3), despite being easy to understand, and S3, S5 and S7 had the lowest confidence medians, 3. The themes explain both patterns.

A. Did They Get In? The Outcome Statement Anchors Understanding (T1)

Participants judged every email first by whether the attacker got in. Explicit outcome lines in green ("No one got in", "Your password has not been changed") were the most valued content and reassured all six: "The green bits no one got in, your password has not been changed, and also those calmed me down" (P2, closing). Five named the outcome as the most useful information, and all six understood the Medium emails' paused state awaiting the number match.

TABLE VI
Themes, Constructs and Prevalence

Theme	PMT construct or frame	P	Refs
T1 Did they get in? The outcome statement anchors understanding	System-response comprehension	6	56
T2 Severity is judged by password knowledge and role, not colour alone	Perceived severity	6	78
T3 Trust is earned by verifiable cues and lost through urgency	Legitimacy	6	102
T4 Coping depends on plain explanations and justified steps	Self-efficacy, response efficacy	6	74
T5 At high stakes, participants route around the email	Self-efficacy, legitimacy	6	46
T6 Contextual detail supports recognition but can feel intrusive	Perceived susceptibility	6	47
T7 Restrictions and effort must fit the event and the role	Response cost	6	43
T8 Routine notifications invite habituation	Emergent: alert fatigue	6	23

P = participants (of 6) supporting the theme; Refs = coded references.

Wording that implied access undermined this anchor. All three S3 viewers read "your administrator account was accessed with the correct password" as a possible break-in despite "permanently blocked": "Access with the correct password, did they get in or not? It says permanently blocked,

so maybe not, but access sounds like they got in" (P4, S3). Two of three S2 viewers found that "ends the unknown session" contradicted "We blocked this sign-in": "The top part says that it's blocked, the bottom one does a text that kind of implies they got in" (P3, S2). P2 and P5 named S3 the most confusing email for this reason.

B. Severity Is Judged by Password Knowledge and Role (T2)

Participants built their own severity model from whether the attacker knew the password and the role at stake. Five judged a correct-password event worse than failed guessing ("what made the difference was whether they had the password and what role I was in", P3, closing), and all six linked seriousness to the role. Colour was the first severity cue for five, so the tiers sometimes clashed with this model: S2 (correct password, orange) felt worse than S5 (failed guessing, red). "It's actually scarier than the red one because they had the correct password and the red ones, they got it wrong" (P1, S2); "They had the password. But it's orange, not red. That's weird" (P5, S2). The tiers follow the model's scores, so the email text must bridge the gap. "Sustained attack" alarmed all three S5 viewers without informing them ("I understand it, but it frightened me", P4, S5).

C. Trust Is Earned by Verifiable Cues and Lost Through Urgency (T3)

Participants judged legitimacy through checkable cues. All six read the absence of a link or request as a sign of genuineness, mostly in Medium emails: "it doesn't have a link and it knows it's a hotel Wi-Fi. A scammer wouldn't know that probably" (P1, S1). Five valued a button showing its destination ("Oh, this one's telling you where to go", P1, S2), and three doubted the S5 and S8 buttons, which did not: "there's no URL on the button and it's an admin log. I'll verify it before trusting further" (P3, S8).

Urgency had the opposite effect. All three S7 viewers matched "Secure my account now" and "Completing this step will immediately restore full access" to phishing they had met: "That sounds like that what's the fake Netflix one said" (P2, S7); "That is exactly the kind of thing in the test e-mail I clicked" (P4, S7); "Immediately restore full access. That's the bait line" (P6, S7). S7 was the only High email with this wording and had the lowest genuineness rating. Three noticed that a prominent button contradicted the advice to type the address: "The button says click now, the box says don't click. I'd go with the box" (P6, S7).

D. Coping Depends on Plain Explanations and Justified Steps (T4)

Confidence depended on understanding terms and believing the step would help. Three did not understand "number match" until S1 or S6 explained it ("So the number matches the number on the screen and you put it into the phone. I see it now", P4, S1), and five were unsure what a "known device" was ("Number match on a known device. I don't know what that means", P4, S5). Where an email stated why an action helps, five believed it would work: "Yes, it should, because new password and the old one stops working, so it explains that very well" (P3, S2). Where it did not, belief fell. All three S8 viewers questioned the new-password step after a blocked reset ("Wait, why would I need a new password? The reset was blocked anyway", P3, S8), and all three S7 viewers were unsure the action made them safe ("It doesn't say it makes me safe", P4, S7).

E. At High Stakes, Participants Route Around the Email (T5)

For administrator and lockout emails, five participants would call the Service Desk or security team first, and five would type id.meridian.com rather than click: "if this is fake and I'm the admin, that's the worst-case scenario. Ringing is safer" (P5, S3); "I would not click that red button. I would call the service desk" (P4, S5). None of the three S7 viewers would use its button ("I wouldn't do what it asks, I'd go around it", P6, S7). These detours are protective, but calls move the load to the Service Desk. Five wanted to know how the security team would contact them and how to spot an impersonator ("If it said our team will give you this reference number when they call", P5, S3), and three wanted a contact route in the "Not you?" boxes, which name the Service Desk without a number ("tell the service desk, but not how to do that", P3, S6).

F. Contextual Detail Supports Recognition but Can Feel Intrusive (T6)

Device, place and network let participants recognise their own activity in S1 and S6 ("Mine, it's the laptop and the hotel. All the details match", P1, S1). All three S4 viewers missed the location absent from that email ("If it said Melbourne, hospital network, I'd think it's a colleague. If it said overseas, I'd worry", P5, S4). Behavioural phrasing felt intrusive to four ("Outside the usual hours, and it is a bit creepy", P2, S6), and three showed that the signals did not fit their working lives: shift work ("if the system thinks 11 PM is weird, it'll think half the hospital is weird", P5, S6), shared ward computers, corporate VPNs and long-haul flights.

G. Restrictions and Effort Must Fit the Event and the Role (T7)

Four wanted to know what still worked while restricted ("As a manager I'd need to know if I can still approve leave requests and stuff", P5, S2), and five weighed the generic restriction list against their role: managers feared losing approvals and financial data, while for regular staff the financial line was irrelevant. Two of three S4 viewers felt punished for guesses they did not make and saw the restriction as open to abuse ("if someone keeps typing my email wrong, my account gets restricted? That happens on the ward all the time", P5, S4).

H. Routine Notifications Invite Habituation (T8)

Most participants already ignore everyday login alerts, and five would stop reading blue emails if these arrived often while still reading red ones: "if I got these often I'd stop reading the blue and orange ones. Red I'd read" (P5, closing). Four expected emails only when something is genuinely unusual. The consistent layout helped four read later emails faster ("I've seen the steps already now", P1, S8), which also suggests the emails could become easy to skim past.

IV. Limitations and Threats to Validity

The findings are indicative: they show which problems arose and why, not how often they would occur.

Study design. Participants role-played hypothetical events and read emails shared on screen, not in their own inbox under time pressure, so stated intentions may overstate real caution. Scenarios told participants whether the activity was theirs ("the scenario says so", P5, S4), removing the recognition task real users face. Reading aloud and probing raised attention far above daily use, probably understating habituation (T8), and order effects were present: three learned "number match" from a later email. These threaten ecological validity; the study tests comprehension and intentions, not behaviour.

Sample. Six participants from team contacts form a small convenience sample that may not reflect a large workforce, though it included two low-familiarity participants and varied work contexts. Each email had three viewers, so "3 of 3" may rest on similar people, and roles were imagined, which limits external validity.

Data collection. A single facilitator was planned for consistency, but five members facilitated, so probing and neutrality varied: in two sessions the facilitator affirmed answers during think-aloud, and one question in another was leading. Sessions ran 23 to 35 minutes against 10 to 15 in the instrument and 45 to 70 in the PICF. Transcripts are uncorrected automatic output, and nine ratings were inferred from context.

Analysis. The team evaluated its own designs, which risks reading the data in their favour. Counts describe this sample only, and three single-item ratings per email support no inference.

Mitigations. Three viewers per scenario in varied order; one script, probe bank and role cards for all facilitators; a reason after every rating; themes requiring more than one participant; and an audit trail (codebook, coded extracts, memos) from quote to theme to recommendation.

V. Recommendations

Under the evidence rule agreed at the Week 11 meeting, each improvement is tied to a theme, a PMT construct, the affected templates and participant evidence. Table VII presents the five refinements expected to have the greatest effect on whether users understand the outcome, trust the email and complete the protective step.

Further recommendations. (a) Add "They had your correct password" to the S2 summary so the text explains its seriousness while the colour stays tied to the score (T2). (b) Replace "outside your usual hours" and "a city you've never signed in from" with factual wording such as "at 11:48 PM, later than you usually sign in" (T6). (c) Keep Medium emails short and link-free, and vary the headline and highlighted signals rather than the layout, since varied warnings habituate less [3] while a fixed layout aids reading (T8). (d) Complete the S5 Service Desk line, which omits the number, and align "may contact you" (S3) with "will follow up" (S5). The revised set should then be tested with a larger, more varied sample in a real inbox.

TABLE VII
REFINEMENT MATRIX

Improvement (templates; theme; construct)	Problem identified (findings)	Actionable change	Design rationale
1. State the outcome first All; T1; threat appraisal, response efficacy	Users could not tell whether the attacker got in: "was accessed" (S3) and "ends the unknown session" (S2) contradicted "blocked" for 3 of 3 and 2 of 3 viewers. Explicit outcome lines reassured all six (III-A).	Add a fixed outcome line as the first sentence of every email, e.g. "They did not get in. Your password has not been changed." S3: "Someone used your correct password to try to sign in at 3:07 AM. We blocked it, so they did not get in." S2: replace "ends the unknown session" with "lets you set a new password so the one they used stops working".	Outcome was the first thing every participant sought, and users want to know who tried to access their account and what happened [2]. A clear outcome lowers the fear that drives avoidance [9]. The wording matches the risk model: blocked or locked events grant no access.
2. Remove urgency and the access promise S7; T3, T4; response efficacy, legitimacy	"Secure my account now" and "will immediately restore full access" read as phishing to 3 of 3 viewers; none would use the button, and all were unsure it made them safe. Lowest genuineness median, 3 (III-C, III-D).	Button "Secure my account" with "Opens id.meridian.com/secure", as in S2 and S4. New line: "This verifies it's you with a number match and lets you set a new password, so the person who requested the reset can't use it. The restriction lifts when you finish. You won't receive another email during this process."	Participants matched urgency and access promises to phishing they had received. The line now states what the step does for safety (response efficacy [8]) and drops "full access", which High risk grants only after recovery. The Week 12 revision kept the single action; the evidence shows "now" must also go.
3. One trusted route S3, S5, S8 buttons; check box in all; T3, T5; self-efficacy, legitimacy	The button contradicted "type id.meridian.com yourself – don't click" (3 participants); S5 and S8 buttons hid their destination (3 doubted them); 5 of 6 would bypass buttons at high stakes (III-C, III-E).	Show "Opens id.meridian.com/…" beside every button. Reword the check box: "Prefer not to click? Type id.meridian.com and choose Secure my account or Recover a locked account. You'll reach the same page."	Makes the cautious route part of the design instead of conflicting advice, supporting self-efficacy [8]. A visible destination was the cue five participants used to trust a button.
4. Define terms and justify every step S2–S5, S7, S8; T2, T4; self-efficacy, response efficacy, severity	"Number match" and "known device" were unclear to 3 and 5 participants; S8's new-password step had no reason (3 of 3); "sustained attack" alarmed without informing (3 of 3) (III-B, III-D).	Define on use: "Number match: type the number shown on the sign-in screen into your authenticator app"; "known device: a phone or computer you have signed in from before, such as your work phone". S8 step 3: "Set a new password. Someone targeted your admin account, so a new password makes sure any details they hold no longer work." S5: "someone repeatedly trying to guess your password".	Self-efficacy depends on understanding the step [8], and participants believed an action would work only when its reason was stated. Factual wording keeps severity proportionate rather than fear-driven [9].
5. Show what still works and how we will contact you High and Critical; "Not you?" boxes; S4; T5–T7; response cost	Users did not know what still worked while restricted (4), how the security team would contact them (5) or whom to call if it was not them (3); S4 omitted location (3 of 3) (III-E, III-F, III-G).	Add a role-specific "Still available / Blocked until you secure your account" list to High emails. Add the Service Desk number to every "Not you?" box. Critical: "Our security team will quote your reference, RBA-…, when they call. If they can't, hang up and call the Service Desk." Add approximate location to S4.	Showing the real impact for the reader's role lowers response cost [7], and a shared reference closes the impersonation gap participants raised. The list matches the High tier, which blocks only sensitive actions.

VI. CONCLUSION

PMT gave the notifications a clear structure: participants understood the events, valued the outcome lines and trusted cues they could check. The study also showed where the design fell short, through wording that blurred whether an attacker got in, urgency that resembled phishing, steps without a stated reason and restrictions that ignored the reader's role. Most fixes are wording changes within the existing template, and together they keep threat and coping in balance while making the safe action also the trusted one.

REFERENCES

[1] S. Wiefling, M. Dürmuth, and L. Lo Iacono, "More than just good passwords? A study on usability and security perceptions of risk-based authentication," in *Proc. 36th Annu. Comput. Secur. Appl. Conf. (ACSAC)*, 2020, pp. 203–218.

[2] T. Wei, D. Wang, Y. Li, and Y. Wang, "'Who is trying to access my account?' Exploring user perceptions and reactions to risk-based authentication notifications," in *Proc. Netw. Distrib. Syst. Secur. Symp. (NDSS)*, San Diego, CA, USA, 2025, doi: 10.14722/ndss.2025.240133.

[3] B. B. Anderson, C. B. Kirwan, J. L. Jenkins, D. Eargle, S. Howard, and A. Vance, "How polymorphic warnings reduce habituation in the brain: Insights from an fMRI study," in *Proc. 33rd Annu. ACM Conf. Human Factors Comput. Syst. (CHI)*, Seoul, Republic of Korea, 2015, pp. 2883–2892.

[4] C. Bravo-Lillo, L. F. Cranor, J. Downs, S. Komanduri, R. W. Reeder, S. Schechter, and M. Sleeper, "Your attention please: Designing security-decision UIs to make genuine risks harder to ignore," in *Proc. 9th Symp. Usable Privacy Secur. (SOUPS)*, Newcastle, U.K., 2013.

[5] RMIT University, "Simple risk model for central SSO platform," INTE2675 Human Centered Security, Assignment 1 material, Melbourne, VIC, Australia, 2026.

[6] R. W. Rogers, "A protection motivation theory of fear appeals and attitude change," *J. Psychol.*, vol. 91, no. 1, pp. 93–114, 1975, doi: 10.1080/00223980.1975.9915803.

[7] R. W. Rogers, "Cognitive and physiological processes in fear appeals and attitude change: A revised theory of protection motivation," in *Social Psychophysiology: A Sourcebook*, J. T. Cacioppo and R. E. Petty, Eds. New York, NY, USA: Guilford, 1983, pp. 153–176.

[8] J. E. Maddux and R. W. Rogers, "Protection motivation and self-efficacy: A revised theory of fear appeals and attitude change," *J. Exp. Soc. Psychol.*, vol. 19, no. 5, pp. 469–479, 1983, doi: 10.1016/0022-1031(83)90023-9.

[9] K. Witte, "Putting the fear back into fear appeals: The extended parallel process model," *Commun. Monogr.*, vol. 59, no. 4, pp. 329–349, 1992, doi: 10.1080/03637759209376276.

[10] D. L. Floyd, S. Prentice-Dunn, and R. W. Rogers, "A meta-analysis of research on protection motivation theory," *J. Appl. Soc. Psychol.*, vol. 30, no. 2, pp. 407–429, 2000.

[11] M. W. van Someren, Y. F. Barnard, and J. A. C. Sandberg, *The Think Aloud Method: A Practical Guide to Modelling Cognitive Processes*. London, U.K.: Academic Press, 1994.

[12] V. Braun and V. Clarke, “Using thematic analysis in psychology,” *Qual. Res. Psychol.*, vol. 3, no. 2, pp. 77–101, 2006, doi: 10.1191/1478088706qp063oa.

[13] V. Braun and V. Clarke, “Reflecting on reflexive thematic analysis,” *Qual. Res. Sport Exerc. Health*, vol. 11, no. 4, pp. 589–597, 2019, doi: 10.1080/2159676X.2019.1628806.

[14] RMIT University, “Week 6: Qualitative and quantitative data analysis for human-centered cybersecurity,” INTE2675 Human Centered Security lecture, Melbourne, VIC, Australia, 2026.

[15] N. McDonald, S. Schoenebeck, and A. Forte, “Reliability and inter-rater reliability in qualitative research: Norms and guidelines for CSCW and HCI practice,” *Proc. ACM Hum.-Comput. Interact.*, vol. 3, no. CSCW, Art. no. 72, Nov. 2019.